

HW06 AI Critique

AI Critique

AI was useful for expanding the API test design quickly, but it was not reliable without source-code review. The clearest weakness was that initial AI-style cases tended to assume ideal validation rules that the SUT does not implement. For example, it expected coupon percentage logic to behave normally and expected admin endpoints to enforce role authorization simply because the specification labels them as admin APIs. The implementation shows otherwise: `/api/apply-coupon` has a broken percentage formula, and `/api/admin/orders` only verifies that a JWT is valid, not that the role is admin. AI also tends to create broad security labels such as IDOR, SQL injection, and role escalation without tying each one to a concrete parameter, database query, or assertion. That makes the output look complete while still missing the real bug oracle. The main reason for these failures is that a model predicts common API behavior from patterns, while this assignment requires checking the exact behavior of a deliberately imperfect SUT. I learned that collaborating with AI works best when I force it through a testing technique step by step, then audit every claim against the specification, seed data, and source code. AI is a strong generator of candidate partitions and checklists, but the human tester must define the oracle, decide which behavior is a genuine defect, and refuse to fabricate execution evidence.